

UNIVERSITEIT VAN PRETORIA
UNIVERSITY OF PRETORIA
YUNIBESITHI YA PRETORIA
Denkleiers • Leading Minds • Dikgopolo tša Dihlalefi

COS700 Research Proposal

A Per-User Behavioural Baseline Framework for Insider Threat Detection in Resource-Constrained Environments

Student name: Selepe Sello

Student number: u20748052

Supervisor(s):
Professor Jan Eloff

Abstract

Insider threats are among the most damaging cybersecurity incidents, with average detection times exceeding six months. Existing lightweight detection systems evaluate all users against a single shared organisational baseline, which produces two distinct failures: legitimate high-privilege users such as database administrators are repeatedly flagged for activity normal for their role, whilst malicious insiders who keep individual metrics below population-level thresholds go undetected. Enterprise User and Entity Behaviour Analytics (UEBA) platforms address this by maintaining per-user baselines, but require infrastructure and licensing that most organisations cannot afford. This research proposes the development and evaluation of a lightweight, per-user behavioural baseline framework that builds individual activity profiles from standard organisational log data, normalises features relative to role groups, and scores deviations against a user's own historical activity. The framework will be evaluated on the CERT Insider Threat Dataset v6.2 and compared against a population-level baseline. The expected outcome is a measurable reduction in missed detections for low-and-slow attacker behaviour and fewer false alerts for high-privilege users. The prototype will be implemented as a deployable Python application requiring no enterprise infrastructure.

Keywords:

insider threat detection, behavioural anomaly detection, per-user baseline, user and entity behaviour analytics, role-aware normalisation, alert fatigue, cybersecurity, machine learning, anomaly scoring, resource-constrained deployment.

1 Introduction

Detecting malicious insider activity is a persistent and structurally difficult problem in applied cybersecurity. Unlike external attackers, insiders already have legitimate access to organisational systems, which makes perimeter-based controls ineffective. The detection challenge therefore lies in distinguishing malicious activity from routine behaviour. The IBM Cost of a Data Breach Report [IBM24] puts the average detection time for insider incidents at 197 days, a figure that reflects both the sophistication of insider evasion and fundamental limitations in how deployed detection systems define normal behaviour.

The dominant approach in lightweight deployed systems is to evaluate all users against a single shared organisational baseline. A model is trained on aggregate population data and raises a flag when any individual user deviates from what the population considers normal. This approach is computationally practical and straightforward to implement, which explains its use in both academic prototypes and commercial lightweight tools [Noe19, SZF25].

However, this approach has a structural limitation that produces two opposing failures at the same time. High-privilege users, including database administrators, system operators, and security analysts, have daily activity patterns that are unusual relative to the general employee population. Bulk file access, after-hours logins, queries across multiple systems, and high print volumes are routine for these roles but would raise concern if performed by a junior analyst. Any system that evaluates both users against the same threshold will repeatedly flag the administrator whilst missing a genuine threat from someone in a lower-privilege role who has increased their activity. Over time, this pattern produces alert fatigue among security analysts, who learn to ignore system alerts, which reduces the practical value of the detection system [Ver24].

The inverse failure is equally serious. A malicious insider who is aware of detection thresholds can deliberately keep each behavioural metric just below the population-level trigger. By spreading activity across multiple sessions and keeping per-session volumes near normal, such an attacker can remove data over weeks or months without triggering any alert. This is the low-and-slow evasion pattern documented in the insider threat literature [CMT12], and it is invisible to systems that evaluate individual records against population averages.

Enterprise UEBA platforms such as Splunk UBA, Exabeam Fusion, and Microsoft Sentinel address this by maintaining per-user behavioural baselines. These platforms track each user's activity over time and raise alerts when an individual deviates from their own historical patterns rather than from the population mean [Gar23]. However, these platforms require significant infrastructure, vendor licensing, and dedicated security operations capacity, placing them out of reach for most organisations.

The per-user baseline approach is therefore known to work and is acknowledged in the academic literature as the correct modelling strategy [LXSL19, YCS+21], yet no lightweight, deployable implementation exists for organisations without enterprise security budgets. This research addresses that gap directly.

The contributions of this research are as follows. First, a per-user behavioural baseline framework is designed and implemented that runs on standard organisational log data without requiring enterprise infrastructure. Second, a role-aware feature normalisation layer is developed that evaluates user

activity relative to their role group rather than the full population. Third, the framework is evaluated against a population-level baseline on a standard benchmark dataset, with the primary outcome being a measurable improvement in the rate of missed detections for low-and-slow attacker behaviour and a reduction in false positives for high-privilege users. Fourth, the design decisions and evaluation results are documented as a contribution to the insider threat detection literature.

2 Problem Statement

Most organisations that cannot afford enterprise security platforms rely on lightweight detection systems that evaluate all users against a single shared baseline derived from the entire employee population. This creates two concrete, observable failures.

First, a database administrator at a mid-sized South African financial institution who routinely accesses hundreds of files per day, logs in after hours, and queries multiple systems will be flagged as a threat by any system trained on population-wide averages, because these activities are anomalous for the general population. The administrator is not a threat; the system is using the wrong point of comparison. Security analysts who receive these repeated false alerts learn over time to discount them, which means that when a genuine threat does occur, the alert is likely to be ignored [Ver24].

Second, a malicious insider in a lower-privilege role who is aware of how detection thresholds are set can spread data removal across many short sessions, keeping per-session activity within what the population considers normal. Such an attacker can operate undetected for months because no single session triggers the threshold, even though the cumulative activity is clearly anomalous relative to that user's own historical pattern [CMT12].

Both failures stem from the same gap: existing lightweight detection systems have no model of what is normal for an individual user in a specific role. This individual-level blind spot is well-documented in the literature [Noe19, SZF25] but remains unresolved in resource-constrained environments, where organisations lack the infrastructure required by enterprise UEBA platforms.

The knowledge gap this research addresses is therefore the following: no published, lightweight framework exists that constructs individual behavioural baselines from standard organisational log data, normalises activity relative to a user's role group, and produces anomaly scores that distinguish genuine individual deviations from role-consistent behaviour, without requiring enterprise infrastructure.

This research question encompasses the following sub-questions:

1. To what extent does a per-user behavioural baseline model reduce the rate of missed detections for low-and-slow insider attacker behaviour compared to a population-level baseline?

2. To what extent does role-aware feature normalisation reduce the false positive rate for high-privilege legitimate users compared to population-level feature evaluation?

3. What is the minimum amount of historical log data needed to construct a stable and reliable individual behavioural baseline for a given user?

4. How does the computational cost of per-user baseline construction and maintenance compare to population-level model training, and is it feasible in a resource-constrained deployment?

5. What additional context does a per-user deviation score give a security analyst relative to a population-level anomaly score, and does it reduce investigation time?

Scope and limitations. This research is limited to behavioural features derived from organisational log files, specifically logon records, file access logs, device usage logs, and print activity. It does not include network packet-level traffic analysis, email content analysis, or real-time streaming deployment. The evaluation is conducted on a single publicly available benchmark dataset (CERT Insider Threat Dataset v6.2) and results may not generalise without further evaluation on other datasets. The research assumes that log data is available in a structured, exportable format and that user role assignments are recorded. Role misclassification and deliberate role-label manipulation by an insider fall outside the scope of this study.

3 Literature Study

This research sits at the intersection of insider threat detection, behavioural anomaly modelling, and explainable machine learning. The following sections review the relevant prior work and identify the specific gap this research addresses. Each body of work is discussed in terms of how it relates to and differs from the present research.

3.1 Insider Threat Detection

The insider threat problem has been studied extensively since the publication of the CERT Insider Threat Dataset [CER16], which established a standard benchmark for evaluating detection systems and is the same dataset used for evaluation in this research. Early work focused on rule-based approaches that flagged users who exceeded fixed thresholds on individual behavioural metrics. These systems are interpretable and computationally inexpensive but are easily evaded and produce high false positive rates for legitimate power users [CMT12]. This research is directly motivated by those limitations.

Later research incorporated machine learning to learn the boundary between normal and malicious behaviour from labelled data. Noever [Noe19] compares classifier performance on the CERT dataset using Random Forest, Decision Tree, Gradient Boosting, and Logistic Regression models. The Random Forest classifier consistently achieves the highest F1-score but, as Noever notes, all models are trained on the population-level aggregate, which limits their ability to distinguish role-consistent behaviour from genuine anomalies. Noever acknowledges this as a direction for future work but does not address it. This research takes that direction as its primary objective.

Shoderu et al. [SZF25] extend insider threat detection to cloud environments, proposing a digital forensic readiness framework that incorporates behavioural analytics. Whilst the framework is technically thorough, it retains population-level anomaly scoring and does not construct per-user baselines. The authors identify the individual-versus-population blind spot in their limitations section, noting that high-privilege cloud administrators are consistently over-flagged. The current research addresses precisely this unresolved limitation.

3.2 User and Entity Behaviour Analytics

UEBA platforms represent the enterprise response to the population-baseline limitation. These platforms maintain a rolling behavioural profile for each individual user, built from historical log data, and alert when current activity deviates significantly from the user's own established baseline [Gar23]. The per-user baseline approach has several demonstrated advantages over population-level modelling: it adapts to legitimate changes in user behaviour over time, it is naturally role-aware because each user's baseline reflects actual activity patterns, and it reduces false positives for power users whose normal activity would trigger population-level alerts.

Liu et al. [LXSL19] formalise the per-user baseline approach using a time-series model of individual behavioural drift, showing that a user's activity can be modelled as a slowly changing baseline with anomalies corresponding to sudden deviations from the individual trend. Their evaluation shows a 14 percentage point improvement in recall over a population-level baseline on a proprietary enterprise dataset. However, the implementation requires a distributed streaming data infrastructure unavailable to most organisations. This is the exact infrastructure gap the current research addresses by designing a framework that operates on static log file exports.

Yuan et al. [YCS+21] extend this work by incorporating role information into the baseline model, showing that normalising user activity relative to a role-peer group reduces false positives for high-privilege users by 31 per cent without degrading recall. Their implementation requires a SIEM platform for data collection, again placing it beyond resource-constrained organisations. The role-aware normalisation component in this research is directly motivated by Yuan et al.'s findings, adapted to operate without SIEM infrastructure.

3.3 Anomaly Detection Techniques

Several anomaly detection techniques are relevant to per-user baseline modelling. Isolation Forest [LTZ08] is well-suited to detecting outliers in high-dimensional behavioural feature spaces without requiring labelled training data, which is an advantage given that insider threat datasets are severely class-imbalanced. Its suitability for this research lies in its ability to score anomalies relative to a restricted neighbourhood, which is compatible with per-user modelling when the reference set is limited to the user's own historical records. Local Outlier Factor [BKNS00] computes anomaly scores by comparing the local density of a sample to the densities of its neighbours, making it similarly compatible with per-user baseline modelling.

Autoencoder-based anomaly detection [HHWB02] trains a neural network to

reconstruct normal behaviour and uses reconstruction error as an anomaly score. This approach shows strong performance when sufficient per-user historical data is available, but degrades noticeably with limited history. This limitation is directly relevant to this research, as it constrains which algorithms are viable for users with short employment history or recent role changes.

3.4 Explainability in Security Systems

Explainability is an operational requirement in security detection systems. A system that flags a user without providing a reason requires the analyst to investigate from scratch, which is time-consuming and inconsistent [LL17]. SHAP (SHapley Additive exPlanations) values provide a principled decomposition of any model's output into per-feature contributions, allowing a system to communicate not only that a user was flagged but which specific behavioural features drove the anomaly score. This is directly relevant to sub-question five of this research, which asks whether per-user deviation scores provide additional context to a security analyst.

Prior work on explainable insider threat detection [LZH20] shows that SHAP-based explanations improve analyst agreement with model recommendations by 23 per cent in a controlled user study. This research incorporates SHAP explanations into the proposed framework, extending this finding to the per-user baseline context.

3.5 Research Gap

The reviewed literature converges on a clear and specific gap. The individual-versus-population blind spot in lightweight detection systems is acknowledged by Noever [Noe19] and Shoderu et al. [SZF25], and is implicitly present in all studies that report high false positive rates for administrators as a limitation. The per-user baseline approach that resolves this is validated in academic work by Liu et al. [LXSL19] and Yuan et al. [YCS+21], but every existing implementation requires infrastructure unavailable to resource-constrained organisations. No published study has implemented, evaluated, and made available a lightweight per-user baseline framework that operates on static log file exports without enterprise infrastructure. This is the gap this research addresses.

4 Methodology

This research uses a quantitative experimental approach. A per-user behavioural baseline framework is designed, implemented, and evaluated by comparing its performance on a standard benchmark dataset against a population-level baseline that reflects current practice in lightweight detection systems. The experimental methodology is appropriate here because the research question is evaluative: the aim is to measure whether one modelling strategy produces better detection outcomes than another under controlled, reproducible conditions. A qualitative or survey-based approach would not produce the statistical evidence needed to answer the sub-questions. A purely mathematical approach would not

be sufficient because the framework's value depends on empirical performance on realistic data.

4.1 Research Design

The research design is a controlled comparison experiment. Two detection models are trained and evaluated on identical data: a population-level baseline model representing current practice, and the proposed per-user baseline framework. The comparison is evaluated on predefined quantitative metrics, with the hypothesis that the per-user model will reduce the rate of missed detections for low-and-slow attacker behaviour and reduce the false positive rate for high-privilege users, without significant loss in overall accuracy.

4.2 Dataset

The primary dataset is the CERT Insider Threat Dataset v6.2 [CER16], the standard benchmark for insider threat detection research. The dataset contains synthetic but behaviourally realistic log records for 1000 simulated users over 18 months, including labelled malicious activity for a subset of users. It includes logon records, file access logs, email metadata, device usage logs, and psychometric scores. Because the dataset is fully synthetic and contains no personal information about real individuals, no ethical clearance is required for its use.

Class imbalance will be addressed using the Synthetic Minority Oversampling Technique (SMOTE), applied to the training set only after the train-test split, to prevent data leakage. The test set will retain the natural class distribution to ensure that evaluation metrics reflect realistic deployment conditions.

4.3 Proposed Framework

The proposed framework consists of three components.

Profile Builder. For each user in the dataset, a behavioural profile is constructed from historical log records. The profile stores per-feature descriptive statistics (mean, standard deviation, and percentiles) computed from that user's own activity over a configurable historical window. Users with insufficient history (fewer than a configurable minimum number of records) are evaluated against a role-group baseline rather than a personal baseline, which addresses the cold-start problem for new employees.

Role-Aware Normaliser. Features are normalised relative to the user's role group rather than the full population. A database administrator's bulk file access count is z-scored against the distribution of file access counts for all database administrators, not against all employees. This removes the systematic false positive that arises when high-privilege users are compared to a population that does not include their peer group.

Anomaly Scorer. At inference time, a new log record is scored by computing the deviation of each feature from the user's personal or role-group baseline. The deviation vector is passed to an anomaly detection model that produces a scalar risk score. Multiple anomaly detection algorithms will be evaluated, including Isolation Forest, Local Outlier Factor, and a one-class SVM, with the best-performing configuration selected for the final evaluation.

4.4 Baseline Model

The population-level baseline model follows the approach used in prior lightweight detection work. A Random Forest classifier is trained on the full training set using population-level features, SMOTE-balanced, and evaluated on the same test set as the proposed framework. This baseline is the direct comparison point for all evaluation metrics. Random Forest is used specifically because Noever [Noe19] identifies it as the strongest-performing classifier on this dataset, making it the most representative population-level baseline available in the literature.

4.5 Evaluation Metrics

The primary evaluation metrics are:

- **Recall (malicious class):** The primary metric, measuring the proportion of malicious users correctly identified. Recall is prioritised over precision because the cost of a missed insider threat substantially exceeds the cost of a false alert in the target deployment context.
- **False Positive Rate (high-privilege subgroup):** Computed separately for users in database administrator, system operator, and security analyst roles, to measure the improvement in false positives for the user group most affected by the population-baseline limitation.
- **F1-Score (malicious class):** The harmonic mean of precision and recall, providing a balanced summary metric.
- **ROC-AUC:** Area under the receiver operating characteristic curve, measuring the model's ability to distinguish between classes across all thresholds.
- **Computational cost:** Profile construction time, inference time per record, and peak memory usage, measured to verify feasibility in a resource-constrained deployment.

4.6 Implementation

The framework will be implemented in Python using scikit-learn [PVG+11] for anomaly detection models, pandas and NumPy for data processing, and SHAP [LL17] for anomaly score explanation. The complete implementation will be made available in a public GitHub repository to support reproducibility. A Streamlit prototype will be developed to demonstrate the framework in a form accessible to a non-technical security manager, providing per-user risk scores and SHAP-based explanations of flagged activity.

All experiments will be conducted on standard consumer hardware (no GPU required) to validate the resource-constrained deployment claim. Any experiment that cannot be completed on consumer hardware will be noted as a limitation.

5 Planning

This research project will be conducted over the 2026 academic year, from February to October, divided into five phases.

5.1 Phase 1: Foundation (March – April)

- Week 1 to 2: Comprehensive literature review of insider threat detection, per-user baseline modelling, and anomaly detection techniques.
- Week 3 to 4: Dataset acquisition, preprocessing pipeline, and exploratory data analysis of the CERT Insider Threat Dataset.
- Week 5 to 6: Population-level baseline model implementation and verification that results are consistent with prior published work on the same dataset.
- Milestone 1: Verified baseline model with documented metrics. Literature review draft committed to version control.

5.2 Phase 2: Framework Implementation (May – June)

- Week 1 to 2: Profile Builder implementation and validation on a sample of users.
- Week 3 to 4: Role-Aware Normaliser implementation and evaluation of false positive rate reduction for high-privilege users.
- Week 5 to 6: Anomaly Scorer implementation and comparison of Isolation Forest, Local Outlier Factor, and one-class SVM on the validation set.
- Week 7 to 8: Integration of all three components into a unified framework and end-to-end pipeline testing.
- Milestone 2: Working per-user baseline framework producing anomaly scores on the test set.

5.3 Phase 3: Evaluation and Analysis (July)

- Week 1: Full evaluation of the proposed framework against the population-level baseline on all primary metrics.
- Week 2: Subgroup analysis of false positive rates for high-privilege users and missed detections for low-and-slow attacker behaviour.
- Week 3: Computational cost measurement and feasibility analysis for resource-constrained deployment.
- Week 4: SHAP explainability integration and qualitative assessment of explanation quality.
- Milestone 3: Complete evaluation results and analysis document.

5.4 Phase 4: Prototype and Report (August – September)

- Week 1 to 3: Streamlit prototype development and demonstration preparation.
- Week 4 to 6: Report writing: introduction, literature review, and methodology chapters.
- Week 7 to 8: Report writing: results, discussion, and conclusion chapters.
- Milestone 4: Complete report draft submitted to supervisor for review.

5.5 Phase 5: Finalisation (October)

- Week 1 to 2: Revisions based on supervisor feedback.
- Week 3: Final proofreading and formatting.
- Final Milestone: Complete report and demonstrable prototype submitted.

5.6 Risk Management

- **Insufficient per-user history for stable baselines:** If the CERT dataset does not provide enough per-user records to construct stable baselines for all users, the cold-start fallback to role-group baselines will be applied and the minimum history threshold will be treated as a research variable.
- **Marginal improvement over baseline:** If the per-user framework does not produce a measurable improvement in the rate of missed detections, the anomaly scoring component will be extended to incorporate temporal sequence features (rolling window aggregates) and the evaluation will document the conditions under which per-user baselines are and are not effective.
- **Computational infeasibility:** If per-user profile construction proves computationally prohibitive on consumer hardware, the profile construction step will be batched and optimised, and the feasibility constraint will be documented as a scope boundary.
- **Timeline delays:** Each phase includes a two-week buffer. Delays in Phase 2 will be absorbed by reducing the number of anomaly detection algorithms evaluated from three to two.

Regular meetings with the supervisor will be scheduled on a fortnightly basis to review progress and address challenges. The research report will be written incrementally throughout the project rather than entirely in the final phase.

References

[BKNS00] Markus M. Breunig, Hans-Peter Kriegel, Raymond T. Ng, and Jörg Sander. LOF: Identifying density-based local outliers. *Proceedings of the ACM SIGMOD International Conference on Management of Data*, pages 93–104, 2000.

[CER16] CERT Division. Cert insider threat dataset v6.2. Technical report, Software Engineering Institute, Carnegie Mellon University, 2016.

[CMT12] Dawn M. Cappelli, Andrew P. Moore, and Randall F. Trzeciak. *The CERT Guide to Insider Threats: How to Prevent, Detect, and Respond to Information Technology Crimes*. Addison-Wesley Professional, 2012.

[Gar23] Gartner Research. Market guide for user and entity behaviour analytics. Technical report, Gartner Inc., 2023.

[HHWB02] Simon Hawkins, Hongxing He, Graham J. Williams, and Rohan A. Baxter. Outlier detection using replicator neural networks. *Proceedings of the International Conference on Data Warehousing and Knowledge Discovery (DaWaK)*, pages 170–180, 2002.

[IBM24] IBM Security. Cost of a data breach report 2024. Technical report, IBM Corporation, 2024.

[LL17] Scott M. Lundberg and Su-In Lee. A unified approach to interpreting model predictions. In *Advances in Neural Information Processing Systems (NeurIPS)*, pages 4765–4774, 2017.

[LTZ08] Fei Tony Liu, Kai Ming Ting, and Zhi-Hua Zhou. Isolation forest. *Proceedings of the IEEE International Conference on Data Mining (ICDM)*, pages 413–422, 2008.

[LXSL19] Fei Liu, Zheng Xu, Kai Shu, and Huan Liu. Insider threat detection with deep neural network. *Computers and Security*, 84:1–15, 2019.

[LZH20] Duc C. Le and A. Nur Zincir-Heywood. Evaluating insider threat detection workflow using supervised and unsupervised learning. *IEEE Security and Privacy Workshops*, pages 270–275, 2020.

[Noe19] David Noever. Machine learning classifiers and the insider threat. *arXiv preprint arXiv:1908.05895*, 2019.

[PVG+11] Fabian Pedregosa, Gaël Varoquaux, Alexandre Gramfort, Vincent Michel, Bertrand Thirion, Olivier Grisel, Mathieu Blondel, Peter Prettenhofer, Ron Weiss, Vincent Dubourg, Jake Vanderplas, Alexandre Passos, David Cournapeau, Matthieu Brucher, Matthieu Perrot, and Édouard Duchesnay. Scikit-learn: Machine learning in Python. *Journal of Machine Learning Research*, 12:2825–2830, 2011.

[SZF25] Gbolahan Shoderu, Tranos Zuva, and Adeyemi Fadahunsi. Digital forensic readiness framework for insider threat detection in cloud environments. *Journal of Information Security and Applications*, 89:103–118, 2025.

[Ver24] Verizon Business. 2024 data breach investigations report. Technical report, Verizon Communications Inc., 2024.

[YCS+21] Fangfang Yuan, Yanan Cao, Yanmin Shang, Yijun Liu, Jianlong Tan, and Binxing Fang. Insider threat detection with deep neural network. *IEEE Transactions on Information Forensics and Security*, 16:4429–4441, 2021.